Graded Lab IR Playbook – Final Report

1. Identify and Categorize the Incident

- **Data Reviewed:**
  - Email header: Sender `attacker@example.com`, Subject *Urgent Account Verification Required!*, URL `http://malicious-site.com/reset`.
  - Network logs: Outbound traffic from workstation `192.168.10.25` to IP `203.0.113.99`.
  - EDR report: Malicious process `invoice.pdf.exe`, MD5 hash `7c9e3a5b6d8f12a4abc9d5678912efab`, C2 connections to `198.51.100.88`.
- **Incident Category:** Phishing → Malware Execution → Command-and-Control (C2) activity.
- **Indicators of Compromise (IOCs):**

- Malicious domain: `malicious-site.com`
- Malicious IPs: `203.0.113.99`, `198.51.100.88`
- File: `invoice.pdf.exe` (MD5: `7c9e3a5b6d8f12a4abc9d5678912efab`)

2. Contain the Incident

- Isolate workstation `192.168.10.25` from the corporate network.
- Block malicious IPs (`203.0.113.99`, `198.51.100.88`) at firewall and proxy.
- Quarantine phishing emails across all mailboxes using email security gateway.
- Disable affected user account temporarily to prevent lateral movement.

3. Analyze the Threat

- **Suspicious File:** `invoice.pdf.exe` disguised as a PDF, executed by the user.
- **Malware Behavior:** Established persistence and connected to external C2 server.
- **Threat Intelligence Correlation:**
  - Hash `7c9e3a5b6d8f12a4abc9d5678912efab` flagged in malware databases.
  - IP `198.51.100.88` identified as known C2 infrastructure.
- **Logged IOCs for monitoring:**

- Domains: `malicious-site.com`
- IPs: `203.0.113.99`, `198.51.100.88`
- File Hash: `7c9e3a5b6d8f12a4abc9d5678912efab`

4. Eradicate the Threat

- Remove malicious file (`invoice.pdf.exe`) and persistence mechanisms.
- Run full EDR and AV scans to clean the workstation.

- Patch vulnerabilities in email filtering and endpoint security.
- Reset user credentials and enforce MFA.

5. Recover and Restore Operations

- Reimage or restore workstation `192.168.10.25` from a clean backup.
- Verify system integrity with EDR and AV scans.
- Reconnect workstation to the network after validation.
- Monitor for residual C2 traffic or abnormal behavior.

6. Post-Incident Review and Reporting

- **Incident Summary:**
  A phishing email tricked an employee into downloading and executing malware (`invoice.pdf.exe`). The malware connected to external C2 infrastructure. Incident was contained by isolating the workstation, blocking malicious IPs, and removing the malware.
- **Actions Taken:** Isolation, blocking, eradication, recovery, credential reset.
- **Process Gaps Identified:**
  - Insufficient phishing awareness training.
  - Lack of attachment sandboxing.
  - No automated blocking of known malicious domains.
- **Recommendations:**

- Update IR playbook with phishing-specific containment steps.
- Enhance email filtering rules.
- Improve user awareness training.

7. Proactive Monitoring and Preventative Actions

- **Monitoring Rules:**
  - Block and alert on connections to known malicious IPs/domains.
  - Detect execution of suspicious file types (e.g., `.exe` masquerading as `.pdf`).
  - Monitor for abnormal outbound traffic patterns.
- **Preventative Measures:**

- Implement advanced email security (sandboxing, DMARC, SPF, DKIM).
- Conduct regular phishing simulations and awareness training.
- Enforce least privilege and application whitelisting.
- Deploy threat intelligence feeds for IOC enrichment.